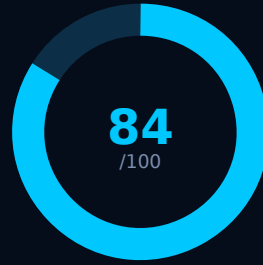


guzel.net.tr

06.06.2026 | Rapor #97

Iyi

Temel guvenlik onlemleri buyuk olcude yerinde.



TR Ort. 58

Siz 84



Puan Dokumu

SPF 14 /20	DMARC 20 /25	DKIM 20 /20	MX 10 /10	SSL 20 /25
---------------	-----------------	----------------	--------------	---------------

E-posta ve SSL Guvenlik Kontrolleri

! SPF Kaydi	20 puan
v=spf1 a mx ip4:31.192.212.2 ip4:31.192.212.32 ip4:185.106.211.31 ip4:31.192.212.38 includ	
+ DMARC Politikasi	25 puan
v=DMARC1; p=quarantine; rua=mailto:abuse@guzel.net.tr	
+ DKIM Imzasi	20 puan
dkim, default	
+ MX Kayitlari	10 puan
ni-spamexperts.guzel.net.tr	
+ SSL/TLS Sertifikasi	25 puan
Let's Encrypt - 38 gun gecerli	

Web Sunucu Guvenlik Basliklari

Toplam skor: 3/5 baslik

- HSTS (Strict-Transport-Security)
- + X-Frame-Options (clickjacking korumasi)
- + X-Content-Type-Options
- Content-Security-Policy (CSP)
- + Referrer-Policy

Risk Istihbarati

+ Veri Sizintisi (HIBP)	Temiz — sizinti kaydi yok
+ Kara Liste (DNSBL)	Temiz — hicbir kara listede yok
+ URLhaus Zararli URL	Temiz — zararli URL listesinde yok
+ USOM Ulusal Kara Liste	Temiz — USOM listesinde yok
+ Golge BT Tespiti (Shadow IT)	5 servis — 0 yuksek riskli (Google Analytics / Tag Manager, Tawk.to, WordPress, Cloudflare...)

Katman 1 Tehdit Istihbarati

+ VirusTotal Domain Reputation	Temiz — 70+ motor zararli isaretlemedi. Reputation skoru: 0
+ IP Kotuye Kullanım Geçmisi	Guven skoru: %0 — son 90 gunde 0 rapor. Konum: US, Cloudflare, Inc.
+ Internet Maruziyeti Analizi	12 CDN beklentisi (US, Cloudflare, Inc.)

MITRE ATT&CK Saldin Senaryolari

Genel Tehdit Seviyesi: Düşük

SPF kaydı eksik olması nedeniyle e-posta kimlik doğrulaması zayıf ve phishing saldırılarına açıktır. Shadow IT bileşenlerinin (Google Analytics, Tawk.to, WordPress) versiyonları bilinmediğinden güncellik doğrulanamayarak potansiyel güvenlik açıkları oluşabilir.

YÜKSEK E-posta Kimlik Sahteciliği ve Phishing Kampanyası

Giris Noktası: Eksik SPF kaydı, saldırganın guzel.net.tr alan adı adına sahte e-postalar göndermesini kolaylaştırır.

Saldiri Zinciri:

- Keşif: Saldırgan WHOIS ve DNS kayıtlarını tarayarak SPF kaydının olmadığını tespit eder.
- İlk Erişim: guzel.net.tr adına kimlik doğrulamasız e-postalar göndererek sosyal mühendislik yapı kurar (kredansiyel avı, ödeme talimatlar
- Yanal Hareket/Kalıcılık: Hedef kullanıcılar kimlik bilgilerini veya para transferi yaparak hasara neden olur.
- Etki: Muhasebe, insan kaynakları veya müdürlük düzeyindeki kişilerin manipülasyonu ile finansal zarara yol açılır.

Etki: Finansal kayıp, müşteri ve iş ortağı güveni kaybı, yasal sorumluluk. Özellikle muhasebe ve yönetim seviyesindeki dolandırıcılık saldırıları yüksek zarar potansiyeline sahiptir.

KVKK: Kurumun adı kötüye kullanılarak müşteri ve çalışan e-postalama listeleri hedef alınabilir; kişisel veri ihlali riski oluşur ve KVKK 5. Madde gereği idari para c

MITRE: T1598 Phishing – Kimlik Bilgisi Avı | T1566 E-posta Tabanlı Saldırı

ORTA Web Uygulaması Bağımlılıklarındaki Bilinmeyen Güvenlik Açıkları

Giris Noktası: WordPress, jQuery ve diğer istemci tarafı kütüphanelerinin sürümü bilinmemektedir; güncellik doğrulanamayan bağımlılıklar potansiyel açıkları içerebilir.

Saldiri Zinciri:

- Keşif: Saldırgan tarayıcı konsolunda jQuery sürümünü veya WordPress eklenti meta etiketlerini belirleyerek bilinen açıkları arar.
- İlk Erişim: Keşfedilen açık varsa, sitedeki form işleme, dosya yükleme veya yönetim panelindeki açığı istismar ederek ilk erişim sağlar.
- Yanal Hareket/Kalıcılık: Web kabuğu yükleyerek veya veritabanını değiştirerek kalıcılık kurması ve yönetim oturumlarına erişim sağlar.
- Etki: Sitenin defacement, e-ticaret verilerinin çalınması, istemci tarafında kötü amaçlı kod enjeksiyonu (malware, kripto-madenci) veya v

Etki: Web sitesinin kullanılabilirliği düşer, müşteri güveni zedelenir, veri ihlali yaşanabilir. Özellikle e-ticaret veya müşteri verileri işleniyor ise iş sürekliliği sekteye uğrar.

KVKK: WordPress veya jQuery açığı üzerinden kişisel veriler (isim, e-posta, telefon, ödeme bilgileri) çalınırsa KVKK ihlali kapsamında 4. Madde (veri işlemede uyum) i

MITRE: T1190 Açık Uygulama İstismarı | T1505 Sunucu Tarafı Yazılım Bileşeni İstismarı

Oncelikli Aksiyon Listesi

1. SPF kaydını yayınlayın (v=spf1 include:cloudflare.com ~all) ve DMARC politikasını p=reject olarak güncelleyin

Phishing saldırılarının en doğrudan ve yüksek olasılıklı vektörüdür; finansal dolandırıcılık ve marka zedelenmesini anında engeller.

2. WordPress, jQuery ve tüm bağımlılıkların güncel sürümde olduğunu doğrulayın; bilinmeyen sürümleri güncelleyin

Eski veya bilinmeyen sürümler bilinen açıklara maruz kalmış olabilir; güncellik doğrulaması veri ihlali ve web uygulaması saldırılarını önler.

